



CIBERSEGURIDAD Y SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN

Phishing

Ingeniería social aplicada a la ciberseguridad



“¿Qué harías si recibieras un correo aparentemente enviado por tu banco solicitando verificar tu cuenta de manera urgente?”

El phishing es la modalidad de delito informático más denunciada a nivel mundial en los últimos años (FBI · IC3).

CONTEXTO

Ingeniería social y el factor humano

Ingeniería social: conjunto de técnicas psicológicas utilizadas para manipular a una persona y lograr que revele información o realice una acción, sin vulnerar directamente un sistema técnico.

Una organización puede invertir en firewalls, cifrado y controles de acceso: si un usuario es engañado para entregar su contraseña, ese esfuerzo técnico pierde efectividad.

El phishing es la manifestación más conocida de la ingeniería social aplicada a entornos digitales.



¿Qué es el Phishing?

Phishing: ataque de ingeniería social en el que un atacante se hace pasar por una entidad legítima —banco, empresa, organismo público, incluso un compañero de trabajo— para engañar a la víctima y lograr que revele información confidencial, realice una acción riesgosa o instale software malicioso.

Origen del término: combinación de “fishing” (pescar) y la “ph” de “phreaking”, popularizado en los años 90. La idea es literal: se lanza un anzuelo esperando que alguien “muerda”.

Objetivo principal: obtener información o acceso mediante el engaño, no necesariamente vulnerando un sistema técnico.

¿QUÉ BUSCA OBTENER EL ATACANTE?



Credenciales de acceso



Información personal (PII)



Información financiera



Acceso a sistemas corporativos



Información corporativa

Esquema general de un ataque



El objetivo no siempre es únicamente robar una contraseña: el phishing también se utiliza como punto de entrada para otros incidentes de seguridad (ransomware, fraude, filtración de datos).

Características principales del Phishing



Suplantación de identidad



Urgencia y presión temporal



Miedo o preocupación



Promesas de beneficios



Solicitudes inesperadas



Enlaces y dominios sospechosos



Archivos adjuntos inesperados



Uso de datos personales para
generar confianza

Principios de ingeniería social aplicados



Autoridad

El mensaje simula venir de un jefe, banco o entidad oficial.



Urgencia

Presiona a decidir rápido, sin pensar críticamente.



Confianza

Se apoya en marcas y contactos conocidos.



Miedo

Amenaza consecuencias negativas inmediatas.



Curiosidad

Invita a abrir un adjunto o enlace “atractivo”.



Escasez

“Último cupo”, “oferta por tiempo limitado”.

Tipos de Phishing (I)

Canales tradicionales y dirigidos



Email Phishing

Masivo, genérico, bajo nivel de personalización. Enviado a grandes volúmenes de destinatarios.



Spear Phishing

Dirigido a una persona, grupo u organización específica, usando información previa (nombre, cargo, proyectos).



Whaling

Variante de spear phishing dirigida a altos ejecutivos. También llamado “fraude del CEO”.



Smishing

Ejecutado mediante SMS o mensajería instantánea (WhatsApp, Telegram).



Vishing

Ejecutado mediante llamadas telefónicas, a veces con voz sintética (IA).

Tipos de Phishing (II)

Canales emergentes y técnicas avanzadas



QR Phishing (Quishing)

Códigos QR maliciosos que redirigen a sitios fraudulentos. El usuario no puede ver fácilmente el destino antes de escanear.



Social Media Phishing

Perfiles falsos, mensajes directos o publicaciones que simulan promociones o alertas de seguridad.



Angler Phishing

Cuentas falsas de atención al cliente en redes sociales que responden a reclamos públicos reales.



Pharming

La víctima puede terminar en un sitio falso incluso escribiendo bien la URL legítima, por manipulación de DNS.

Tabla comparativa de tipos de Phishing

Tipo	Canal	Personalización	Objetivo principal
Email Phishing	Correo masivo	Bajo	Credenciales / datos generales
Spear Phishing	Correo dirigido	Alto	Acceso a persona o área específica
Whaling	Correo / llamada	Muy alto	Fraude financiero, filtración estratégica
Smishing	SMS / mensajería	Medio	Datos personales o financieros
Vishing	Llamada / voz	Medio-alto	Códigos de verificación, datos sensibles
Quishing (QR)	Código QR	Medio	Redirección a sitio fraudulento
Social Media	Redes sociales	Medio	Credenciales / difusión de malware
Angler Phishing	Redes (soporte falso)	Medio-alto	Robo de datos vía falso soporte
Pharming	Redirección DNS	Bajo (técnico)	Redirección silenciosa a sitio falso

Casos reales y conocidos

2013–2017

Google y Facebook

Spear phishing / BEC: proveedor falso logró transferencias por más de USD 100 M.

DOJ (EE. UU.)

2020

Twitter (X)

Vishing a empleados: acceso a herramientas internas y compromiso de cuentas verificadas.

Twitter Support · Reuters

2021–2023

Sector salud / gobierno

Email phishing como vector inicial de ataques de ransomware.

CISA · FBI/IC3

2023–2024

Auge del Quishing e IA

Códigos QR maliciosos y mensajes generados con IA, evadiendo filtros tradicionales.

Reportes de la industria

Factor humano y controles técnicos



Factor humano

- Concientización y capacitación periódica
- Verificación del remitente y del dominio
- Revisión de enlaces antes de hacer clic
- Desconfianza ante solicitudes urgentes
- Verificación por otro canal
- Reporte inmediato de incidentes



Controles técnicos

- MFA (autenticación multifactor)
- Gestores de contraseñas
- Filtros de correo y anti-phishing
- SPF, DKIM y DMARC (validan el remitente real)
- Antimalware y EDR en endpoints
- Monitoreo de comportamiento anómalo

Medidas organizacionales



Políticas de seguridad claras



Simulaciones de phishing



Planes de respuesta ante incidentes



Principio de mínimo privilegio



Capacitación continua



Procedimientos de reporte

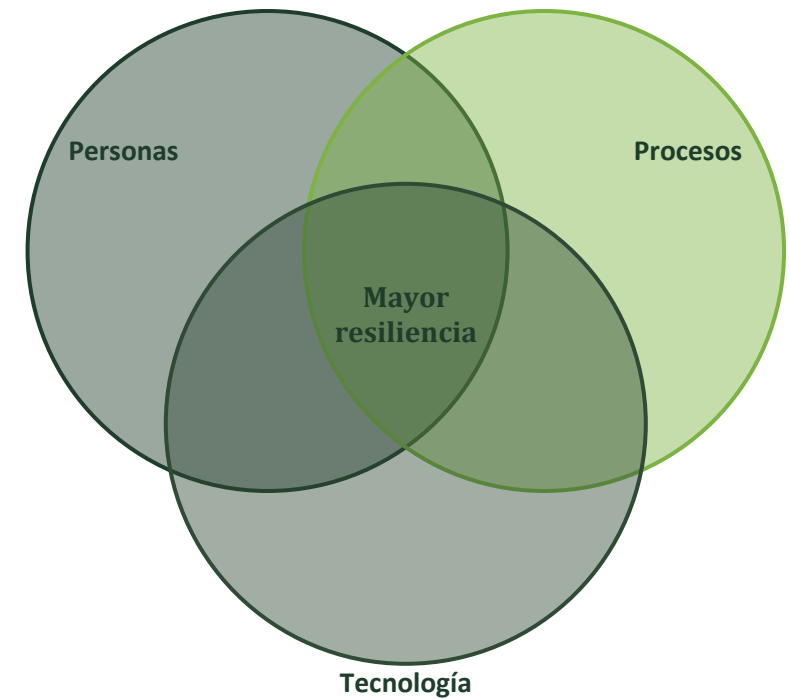


Gestión de accesos



Cultura de seguridad compartida

DEFENSA EN PROFUNDIDAD



Personas + Procesos + Tecnología = Mayor resiliencia frente al phishing

¿Detectás las señales de phishing?

Correo de ejemplo (ficticio)

De: soporte@bancosegur0-online.com

Asunto: ACCIÓN REQUERIDA: Verifique su cuenta en 24 horas

Estimado cliente,

Hemos detectado actividad inusual en su cuenta. Debe verificar su identidad de inmediato o su cuenta será suspendida permanentemente.

Haga clic para confirmar sus datos: [\[Verificar mi cuenta ahora\]](#)

Si no completa este proceso dentro de las próximas 24 horas, perderá el acceso a sus fondos.

Atentamente,
Departamento de Seguridad

“¿Qué elementos de este mensaje les hacen pensar que podría tratarse de un intento de phishing?”



Dominio del remitente alterado



Urgencia extrema (24 horas)



Amenaza / generación de miedo



Saludo genérico, no personalizado



Enlace como única vía de “solución”

Conclusión

1



El phishing se basa, ante todo, en la manipulación psicológica y la ingeniería social.

2



Se presenta a través de múltiples canales y evoluciona con nuevas tecnologías, incluida la IA.

3



La prevención requiere usuarios capacitados, procesos adecuados y controles tecnológicos.

En un mundo donde cualquier mensaje puede ser falsificado, verificar antes de confiar no es desconfianza: es responsabilidad.

Bibliografía y fuentes



- CISA — Cybersecurity and Infrastructure Security Agency, recursos y alertas sobre phishing.
- NIST — National Institute of Standards and Technology, publicaciones sobre concientización en ciberseguridad.
- ENISA — ENISA Threat Landscape (informes anuales de amenazas de la Unión Europea).
- FBI / IC3 — Internet Crime Complaint Center, Internet Crime Report (informes anuales).
- OWASP — Open Worldwide Application Security Project, recursos de buenas prácticas.
- U.S. Department of Justice (DOJ) — documentación del caso Google/Facebook (E. Rimasauskas).
- Twitter/X — comunicado oficial sobre el incidente de julio de 2020; cobertura de Reuters.
- Informes anuales de amenazas de proveedores de seguridad reconocidos (Proofpoint, Microsoft, KnowBe4).